

Threat Analysis Report

รายงานวิเคราะห์ ชุดเครื่องมือ WebShell
ru_RU_lite.mo.php ของกลุ่ม NXBBSEC

15/11/2025

TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
การวิเคราะห์เชิงเทคนิค.....	4
Technique Tactics and Procedures (MITRE ATT&CK).....	5
Indicator of Compromise (IOCs).....	6
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	7



บทสรุปสำหรับผู้บริหาร

เมื่อวันที่ 15 พฤศจิกายน 2568 กลุ่ม NXBBSEC เผยแพร่เครื่องมือ WebShell ที่ถูกฝังบนเว็บไซต์ http://foto-prostitutok.com/wp-content/languages/ru_RU_lite.mo.php โดยไฟล์ WebShell ru_RU_lite.mo.php ถูกตั้งชื่อไฟล์ให้คล้ายกับไฟล์ภาษาของระบบจัดการเว็บไซต์ WordPress

WebShell นี้อนุญาตให้ผู้ไม่ประสงค์ดีสามารถควบคุมเครื่องเซิร์ฟเวอร์ได้จากระยะไกลผ่านหน้าเว็บเบราว์เซอร์ โดยมีความสามารถครอบคลุมทั้งการจัดการไฟล์, การรันคำสั่ง Linux/Windows, การโจมตีฐานข้อมูล, และยังสามารถรวมชุดเครื่องมือสำหรับโจมตีต่อเนื่อง เช่น การสแกนหาช่องโหว่เว็บไซต์อื่นหรือการเดารหัสผ่าน (Brute Force)



(ภาพเว็บไซต์ที่ถูกฝัง WebShell ru_RU_lite.mo.php)

```
<title>Marco Priv 8 Shell</title>

<BODY OnKeyPress="GetKeyCode();" text=#ffffff bottomMargin=0 bgColor=#000000 leftMargin=0 topMargin=0
rightMargin=0 marginheight=0 marginwidth=0><center><TABLE style="BORDER-COLLAPSE: collapse" height=0
cellSpacing=0 borderColorDark=#666666 cellPadding=2 width="100%" bgcolor=#000000 borderColorLight=#c0c0c0
border=1 bordercolor=#C0C0C0"><tr><th width="101%" height="100%" nowrap bordercolor=#C0C0C0 valign="top"
colspan="2"><center><font color=#0033FF>
| | <pre><center><br></span><span style="font-weight:bold; text-shadow:white 0px 0px 8px; color:white"><font
color=beyaz>#Marc0 Priv8 2012 Server Attack <---- ajanlar.org # m4rc0-security.blogspot.com/#</pre>
<hr>
<body bgcolor= "lightgray">

<script defer src="https://static.cloudflareinsights.com/beacon.min.js/vcd15cbe7772f49c399c6a5babf22c1241717689176015" in
</font><h5></font></p><center><font face="tahoma" color="blue"><br><span style="font-weight:bold; text-shadow:blue 0px 0px 8
<a href="?red=finder"><font color="green">| Admin Panel Scanner| </font></a>&nbsp;&nbsp;&nbsp;<a href="?red=zone"><font color=
</center></th></tr><tr><td>
```

(ภาพโค้ดจาก ru_RU_lite.mo.php)



การวิเคราะห์เชิงเทคนิค

1. Webshell (ru_RU_lite.mo.php)

กลไกการทำงาน:

- **File Name:** ไฟล์ถูกตั้งชื่อว่า ru_RU_lite.mo.php ซึ่งจงใจเลียนแบบไฟล์แปลภาษา (Localization file) ของ WordPress ที่ปกติจะเป็นนามสกุล .mo หรือ .po

File Manipulation & Upload: มีฟังก์ชันอัปโหลดไฟล์ผ่านตัวแปรชื่อ gazaUP ซึ่งช่วยให้ผู้ไม่ประสงค์ดีสามารถฝัง Backdoor หรือเครื่องมือโจมตีเพิ่มเติมได้

Code Evidence: `<input type='file' name='gazaUP' size='23' >`

- **Security Bypass & File Reading:** มีฟังก์ชัน Read ที่ให้ผู้ใช้เลือกวิธีการอ่านไฟล์ได้หลายแบบเพื่อหลบเลี่ยงการบล็อก (Disable Functions) ของ Server เช่น curl, show_source, include, fread, posix_getpuid

Code Evidence: `<select name='function_tkl'><option value='curl'>curl</option>`

- **Post-Exploitation Tools:** ภายใน Webshell มีเมนูเครื่องมือสำเร็จรูปสำหรับโจมตีต่อ (Lateral Movement) ได้แก่

- **Admin Panel Scanner:** สแกนหาหน้า Login ของผู้ดูแลระบบ

`<a href="?red=finder"><font color="green">| Admin Panel Scanner| </font></a>`

- **Wordpress Brute Force:** เครื่องมือเดารหัสผ่าน WordPress

`<a href="?red=bruteci"><font color="green">| Wordpress Brute Force |</font></a>`

- **Symlink Attack:** การโจมตีข้าม User บน Shared Hosting

`<input type='submit' name='tool' value='symlink' size='10' >`

- **Server Script Lister:** ค้นหาสคริปต์อื่นๆ ในเซิร์ฟเวอร์เดียวกัน

`<a href="?red=massftp"><font color="green">| MassFtp Cracker|</font></a>`



Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application
Persistence	T1505.003	Server Software Component: Web Shell
Defense Evasion	T1036.005	Masquerading: Match Legitimate Name
Command and Control	T1071.001	Application Layer Protocol: Web Protocols
Execution	T1059.003	Command and Scripting Interpreter
Discovery	T1082	System Information Discovery
Credential Access	T1110	Brute Force
Lateral Movement	T1210	Exploitation of Remote Services
Collection	T1005	Data from Local System
Impact	T1491	Defacement



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

File Name: ru_RU_lite.mo.php

MD5

8690a115044b032e60b6b71e576d6980

SHA-1

5dd5d2feeb4d32174464eef7820f7241dbdfe034

SHA-256

26d8dcf263af81f87dc3df126f0279392eddc0167caf8a5a94476e33ae01f8f3



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตรวจสอบความเปลี่ยนแปลงของไฟล์ : ติดตั้งระบบหรือเปิดใช้งานฟังก์ชันเพื่อตรวจสอบการสร้างไฟล์ใหม่ หรือการแก้ไขไฟล์ในโพลเดอร์สำคัญของ Web Application โดยเฉพาะโพลเดอร์ที่เปิดให้อัปโหลดไฟล์ได้
- เฝ้าระวังการเรียกใช้งานไฟล์สคริปต์ด้วย HTTP Method: POST ที่มีความถี่สูงผิดปกติ หรือมาจาก IP Address ที่ไม่คุ้นเคย
- เฝ้าระวังการเชื่อมต่อเครือข่าย (Network Monitoring): ตรวจสอบ Traffic ขาออกจาก Web Server ว่ามีการพยายามเชื่อมต่อไปยังพอร์ตแปลกปลอม หรือ IP ปลายทางที่มีประวัติเป็น Malicious (C2 Server) หรือไม่

การป้องกัน (Prevention)

- อัปเดตระบบ: ดำเนินการอัปเดตระบบปฏิบัติการ และซอฟต์แวร์ CMS ให้เป็นเวอร์ชันล่าสุด เพื่อปิดช่องโหว่ที่เปิดโอกาสให้ผู้โจมตีเจาะระบบเข้ามาได้
- ตรวจสอบความปลอดภัยของการอัปโหลดไฟล์: ตรวจสอบไฟล์ที่อัปโหลดอย่าง เพื่อป้องกันเทคนิคการปลอมแปลง และปิดการรันสคริปต์ในโพลเดอร์ Upload
- ติดตั้ง Web Application Firewall (WAF): เพื่อช่วยกรอง Traffic อันตรายและบล็อกรูปแบบการโจมตีก่อนที่จะเข้าถึงตัว Server

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ : หากตรวจพบการบุกรุกหรือการทำงานของ Webshell ให้รีบตัดการเชื่อมต่อเครื่อง Server นั้นออกจากเครือข่ายภายนอกทันที เพื่อป้องกันการส่งการระยะไกล (C2) หรือการใช้เครื่องเป็นฐานโจมตีต่อไปยังเครื่องอื่น (Lateral Movement)
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics) เก็บสำรอง Log Files และตัวอย่างไฟล์ Webshell ที่พบไว้เพื่อวิเคราะห์หาวิธีการเจาะระบบ (Initial Access) และเตรียมป้องกันการถูกโจมตีซ้ำในรูปแบบเดิม
- กำจัดภัยคุกคาม : ลบไฟล์ Webshell หลักและค้นหาไฟล์ Backdoor ที่ถูกฝังไว้ทั้งหมด โดยใช้ข้อมูล IOCs พร้อมทั้งตรวจสอบ Scheduled Task (Cron Jobs) ว่ามีการฝังคำสั่งให้ดาวน์โหลด Webshell กลับมาใหม่หรือไม่



- กู้คืนระบบ: กู้คืนระบบจาก Backup ที่ปลอดภัยหลังจากได้รับการยืนยันว่าได้ทำการอัปเดตความปลอดภัยและแก้ไขช่องโหว่ต่าง ๆ
- รีเซ็ตรหัสผ่าน: เปลี่ยนรหัสผ่านของผู้ดูแลระบบ, รหัสผ่านฐานข้อมูล, FTP, และ SSH ทั้งหมดทันที เนื่องจากมีความเสี่ยงสูงที่รหัสผ่านชุดเดิมจะถูกขโมยผ่าน Webshell ไปแล้ว
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th